Federated Learning for Privacy-Preserving Cyber Threat Intelligence Sharing

Arun Teja Dadala
Student ID: x25101013
H9AIMLC – AI/ML in Cybersecurity
National College of Ireland
Dublin, Ireland

***Abstract*—Organisations face significant barriers to sharing cyber threat intelligence (CTI) due to privacy regulations, competitive concerns, and the risk of exposing sensitive network configurations. This study proposes a federated learning (FL) framework that enables cross-organisational threat intelligence sharing while preserving data sovereignty. Using UNSW-NB15, CIC-IDS2017, and NSL-KDD benchmark datasets partitioned into non-IID distributions, we evaluate three aggregation strategies—FedAvg, Krum, and coordinate-wise Median—under differential privacy constraints on CPU-only hardware. The framework simultaneously addresses privacy preservation through (ϵ,δ)-differential privacy, Byzantine robustness via Krum and Median aggregation, and computational feasibility for organisations without GPU infrastructure. Results demonstrate that the federated approach achieves detection accuracy comparable to centralised baselines while maintaining formal privacy guarantees and Byzantine fault tolerance.**

***Index Terms*—Federated Learning, Cyber Threat Intelligence, Differential Privacy, Byzantine Robustness, Intrusion Detection**

I. Introduction

Organisations face substantial difficulties in collectively defending against advanced cyber threats due to barriers in sharing threat information. Privacy concerns regarding confidential security data, compliance with GDPR and similar regulations, and the competitive risks of exposing network topologies create significant obstacles to collaborative threat intelligence sharing. Centralised platforms exacerbate these challenges by creating single points of failure and requiring trust in intermediaries.

Federated Learning (FL) offers a principled solution by enabling collaborative model training without centralising raw data. Each organisation trains locally on its own security logs and shares only model parameters with an aggregation server, thereby preserving data sovereignty while enhancing collective threat detection capability [1], [2].

This study addresses the research question: *Can a federated learning framework enable effective cross-organisational threat intelligence sharing while guaranteeing formal differential privacy, maintaining intrusion detection accuracy comparable to centralised baselines, and remaining computationally feasible for CPU-only deployment?*

Three publicly available benchmark datasets—UNSW-NB15, CIC-IDS2017, and NSL-KDD—are employed to capture diverse attack types, traffic patterns, and feature distributions representative of real network environments [3].

II. Related Work

A. Foundational Federated Learning and Privacy

McMahan et al. [1] introduced FedAvg, the foundational algorithm for federated learning that demonstrated how distributed clients can collaboratively train a shared model by communicating only parameter updates rather than raw data. Their work established the communication-efficiency advantages of performing multiple local SGD steps before aggregation, which remains the dominant paradigm in FL research. However, the original FedAvg formulation assumed honest participants and IID data distributions, leaving Byzantine robustness and non-IID convergence guarantees as open problems that subsequent work has sought to address.

Dwork et al. [4] laid the theoretical foundations of differential privacy by formalising the notion that a mechanism's output should be statistically indistinguishable whether or not any single individual's data is included. Their calibration of Laplace and Gaussian noise to query sensitivity remains the gold standard for privacy-preserving data analysis. While the original framework targeted statistical databases rather than machine learning, it provided the mathematical toolkit—composition theorems, sensitivity analysis, and privacy loss accounting—upon which all subsequent DP-ML work is built.

Abadi et al. [5] extended differential privacy to deep learning by introducing the DP-SGD algorithm, which clips per-sample gradients and adds calibrated Gaussian noise during training. Their moments accountant technique provides tighter privacy loss composition than naïve sequential composition, enabling practical training of deep networks with meaningful privacy guarantees. Nevertheless, their approach was designed for centralised training and incurs non-trivial accuracy costs, particularly on smaller datasets; adapting DP-SGD to the federated setting introduces additional challenges around per-client versus per-sample privacy accounting that remain actively researched.

Kairouz et al. [6] produced the most comprehensive survey of federated learning to date, systematically cataloguing open problems across privacy, robustness, fairness, and systems efficiency. Their taxonomy of threat models—distinguishing between honest-but-curious servers, malicious clients, and collusion scenarios—provides an essential framework for evaluating FL security claims. Despite its breadth, the survey ac-

knowledges that many proposed solutions remain theoretical, with limited empirical validation on realistic, heterogeneous deployments.

B. Byzantine Robustness and Secure Aggregation

Blanchard et al. [7] introduced Krum, the first provably Byzantine-tolerant aggregation rule for distributed machine learning. By selecting the client update whose sum of squared distances to its nearest neighbours is minimised, Krum guarantees convergence even when up to $f < K/2 - 1$ of K clients submit arbitrary (potentially adversarial) updates. The theoretical contribution is significant, but Krum's selection of a single client per round discards information from honest participants, reducing statistical efficiency and slowing convergence compared to averaging-based methods.

Yin et al. [8] established information-theoretic lower bounds for Byzantine-resilient distributed learning and proposed coordinate-wise median and trimmed mean estimators that achieve optimal statistical rates under Byzantine corruption. Their analysis demonstrates that robust aggregation need not sacrifice asymptotic convergence guarantees, providing theoretical justification for the Median aggregation strategy employed in our framework. However, their analysis assumes IID data across honest workers, and the impact of non-IID distributions on the breakdown point of these estimators remains insufficiently characterised.

Bonawitz et al. [9] developed a practical secure aggregation protocol that enables the server to compute the sum of client updates without observing individual contributions, using secret sharing and key agreement primitives. This cryptographic approach provides a complementary privacy guarantee to differential privacy: while DP bounds what can be inferred from the aggregate, secure aggregation prevents the server from inspecting individual updates entirely. The protocol's communication overhead scales as $O(K^2)$ in the number of clients, which can become prohibitive for large federations, and it does not protect against inference attacks on the aggregate itself.

C. Threat Intelligence Sharing and FL for IoT Security

Barnum [10] introduced the Structured Threat Information eXpression (STIX), which has become the de facto standard for representing and exchanging cyber threat intelligence. STIX provides a rich ontology for describing threat actors, campaigns, indicators of compromise, and courses of action in a machine-readable format. While STIX and its companion transport protocol TAXII enable automated CTI sharing, they operate on explicit threat indicators rather than learned models, and they do not address the privacy concerns inherent in sharing raw observables that may contain sensitive network metadata.

Nguyen et al. [11] provided an extensive survey of federated learning for IoT, covering applications in smart healthcare, autonomous vehicles, and edge computing alongside security use cases. Their analysis of communication efficiency techniques—including model compression, gradient quantisation, and asynchronous aggregation—offers practical strategies for deploying FL in bandwidth-constrained IoT environments. However, the survey's IoT focus means that enterprise-scale CTI scenarios with richer feature spaces and more complex regulatory requirements receive limited attention.

D. FL-Based Intrusion Detection Systems

Buyuktanir et al. [2] present a comprehensive taxonomy of FL-based IDS architectures covering over 80 recent studies, identifying non-IID data distributions and adversarial robustness as the two most critical open challenges. Their systematic categorisation of aggregation strategies, model architectures, and threat models provides an invaluable reference for FL-IDS research. However, the survey remains entirely analytical and lacks any empirical evaluation; no experiments are conducted to compare Byzantine-robust aggregation methods across multiple benchmark datasets, leaving a gap between their theoretical recommendations and practical validation.

Timofte et al. [3] demonstrated formal (ϵ,δ)-differential privacy in a federated IDS setting, achieving above 90% accuracy on the UNSW-NB15 dataset while providing rigorous privacy accounting through Rényi differential privacy composition. Their work is notable for being among the first to combine formal DP guarantees with practical intrusion detection performance thresholds. Nevertheless, their evaluation was restricted to a single dataset with IID partitioning, which does not reflect the heterogeneous data distributions encountered across real organisations, and they did not report computational overhead or assess CPU-only feasibility.

Tom et al. [12] provided a thorough survey of FL applications in industrial IoT security, evaluating hierarchical and peer-to-peer FL architectures and offering useful deployment guidelines for resource-constrained environments. Their analysis of communication overhead across different FL topologies is particularly valuable for practical deployments. However, the work focuses exclusively on IoT-centric threat models and lightweight sensor data, limiting its applicability to enterprise-grade CTI sharing scenarios that involve richer feature sets and more complex attack taxonomies.

Ragab et al. [13] achieved high detection accuracy (above 97%) using Harris Hawk optimisation (HHO) for automated hyperparameter tuning within a federated IoT intrusion detection framework, demonstrating that metaheuristic search can effectively replace manual tuning in distributed settings. The integration of nature-inspired optimisation with FL is a creative contribution that reduces the burden of hyperparameter selection across heterogeneous clients. Yet their framework assumed reliable GPU connectivity at each client site and did not evaluate robustness against Byzantine or adversarial participants, which limits real-world applicability.

Jianping et al. [14] employed federated attention-based graph neural networks (GNNs) for privacy-preserving network attack detection, leveraging graph structure to capture inter-host communication patterns that tabular models miss. Their attention mechanism provides interpretable feature importance scores, which is a significant advantage for SOC

analysts. However, the GNN computational requirements—including neighbourhood sampling, message passing, and attention weight computation—preclude deployment on CPU-only infrastructure, and no differential privacy analysis was performed.

Abd Elaziz et al. [15] explored Tab Transformers with PSO and GA hyperparameter optimisation in a federated learning context, demonstrating that transformer-based architectures can capture complex feature interactions in network traffic data. The dual-optimiser approach (PSO for global search, GA for fine-tuning) yielded consistently strong results across multiple attack categories. However, the study lacked comparison with computationally lighter alternatives such as MLPs, and Tab Transformer inference latency may be prohibitive for real-time intrusion detection on resource-constrained hardware.

Amin et al. [16] demonstrated that Krum and Median aggregation strategies can maintain resilience against adversarial model updates, achieving 93.7% accuracy on NSL-KDD even in the presence of Byzantine clients. Their systematic comparison of robust aggregation methods under varying fractions of compromised clients provides practical guidance for selecting aggregation strategies based on threat models. Nonetheless, their evaluation was limited to a single dataset, and they did not analyse computational overhead on CPU-only hardware or investigate the interaction between Byzantine-robust aggregation and differential privacy mechanisms.

Bagdasaryan et al. [17] exposed a critical vulnerability in federated learning by demonstrating that a single malicious participant can inject a backdoor into the global model through carefully crafted model updates that appear benign under standard aggregation. Their model replacement attack achieves high backdoor accuracy while maintaining the model's performance on the main task, making detection exceedingly difficult. This work underscores that Byzantine-robust aggregation methods such as Krum, while effective against random Byzantine failures, may be insufficient against sophisticated, targeted poisoning attacks that are designed to evade distance-based defences.

Zhu et al. [18] demonstrated that shared gradients in distributed learning can be exploited to reconstruct individual training samples with high fidelity, an attack they term "deep leakage from gradients." Their optimisation-based reconstruction achieves pixel-level accuracy on image data and can recover text inputs from language model gradients. This result has profound implications for federated learning privacy claims: even without sharing raw data, the communicated model updates can leak substantial information about local training examples, motivating the necessity of differential privacy or secure aggregation as complementary protections beyond the structural privacy of FL itself.

III. Methodology and Implementation

A. Dataset Preparation

Three benchmark IDS datasets are employed to capture diverse network environments and attack taxonomies:

UNSW-NB15 contains 2,540,044 records with 49 features extracted from raw packet captures, covering nine attack categories (Fuzzers, Analysis, Backdoors, DoS, Exploits, Generic, Reconnaissance, Shellcode, Worms). After removing duplicate entries and records with missing values, 257,673 samples are retained for experimentation.

CIC-IDS2017 comprises 2,830,743 flow-level records characterised by 78 features derived from CICFlowMeter, representing benign traffic and 14 attack types including brute-force, DDoS, web attacks, and infiltration. After cleaning infinite values and NaN entries, 2,273,097 samples remain.

NSL-KDD provides 148,517 records (125,973 training, 22,544 testing) with 41 features and four attack categories (DoS, Probe, R2L, U2R). This dataset addresses known issues with the original KDD Cup 99 dataset by removing redundant records.

All datasets undergo a unified preprocessing pipeline: (1) categorical features are one-hot encoded; (2) numerical features are standardised to zero mean and unit variance using `StandardScaler`; (3) labels are binarised into *normal* and *attack* classes; and (4) the combined feature space is reduced to a common dimensionality of 40 features via variance-based feature selection. Each dataset is split 80/20 into training and test partitions prior to federated partitioning.

Non-IID data heterogeneity across $K = 5$ federated clients is simulated using a Dirichlet distribution with concentration parameter $\alpha = 0.5$. For each class c, client k receives a fraction $p_{k,c} \sim \text{Dir}(\alpha)$ of class-c samples, producing realistic imbalanced local datasets that mirror the heterogeneous threat landscapes observed across different organisations.

B. Federated Learning Framework

A lightweight multi-layer perceptron (MLP) architecture is deployed across all clients, consisting of an input layer (40 neurons), two hidden layers (64 and 32 neurons respectively) with ReLU activations and dropout ($p = 0.2$), and a softmax output layer (2 neurons). The model totals approximately 5,000 trainable parameters, ensuring computational feasibility on CPU-only hardware.

Three aggregation strategies are evaluated, each formalised below:

1) FedAvg Aggregation: The Federated Averaging algorithm [1] computes the global model as a weighted average of client parameters, proportional to each client's local dataset size:

$$w^{t+1} = \sum_{k=1}^{K} \frac{n_k}{n} w_k^t \tag{1}$$

where w_k^t denotes the model parameters of client k at communication round t, n_k is the number of training samples at client k, and $n = \sum_{k=1}^{K} n_k$ is the total number of samples across all clients.

2) Krum Aggregation: Krum [7] provides Byzantine fault tolerance by selecting the single client model whose parameters are closest to the majority of other clients. The selection criterion is:

$$\text{Krum}(w_1, \ldots, w_K) = w_{i^*} \tag{2}$$

where

$$i^* = \arg\min_i \sum_{j \in \mathcal{N}_i} \|w_i - w_j\|^2 \tag{3}$$

and $\mathcal{N}_i$ denotes the set of $K-f-2$ nearest neighbours of client i (measured by Euclidean distance in parameter space), with f representing the maximum number of tolerated Byzantine clients. In our configuration with $K = 5$ clients and $f = 1$, each client's score is computed using its $K-f-2 = 2$ nearest neighbours.

3) Coordinate-wise Median Aggregation: The Median aggregation strategy computes the global model parameter-by-parameter as the median of client contributions:

$$w_j^{t+1} = \text{median}(w_{1,j}^t, \ldots, w_{K,j}^t) \quad \text{for each parameter } j \tag{4}$$

This approach is robust to outliers because the median is unaffected by extreme values from up to $\lfloor (K-1)/2 \rfloor$ Byzantine clients, providing a breakdown point of nearly 50% [8].

C. Differential Privacy

(ϵ,δ)-differential privacy [4], [5] is implemented via calibrated Gaussian noise addition to client model parameters before aggregation, with $\delta = 10^{-5}$ and varying $\epsilon \in \{0.1, 0.5, 1.0, 2.0, 5.0, 10.0\}$. Client model updates are first clipped to a sensitivity bound S (set to 1.0) and then perturbed:

$$\tilde{w} = w + \mathcal{N}(0, \sigma^2 \cdot S^2) \tag{5}$$

where the noise scale σ is calibrated according to the Gaussian mechanism to satisfy the desired (ϵ, δ)-DP guarantee. Specifically, $\sigma = \frac{\sqrt{2\ln(1.25/\delta)}}{\epsilon}$, ensuring that the probability of distinguishing between neighbouring datasets is bounded by e^ϵ with failure probability at most δ.

D. Training Procedure

The federated training procedure is summarised in Algorithm 1. Each communication round consists of local training at each client followed by secure parameter upload and global aggregation.

Training is conducted for $T = 20$ communication rounds with $E = 3$ local epochs per round, a learning rate of $\eta = 0.001$ using the Adam optimiser, and a batch size of 64. All experiments are executed on CPU-only hardware (Intel Core i7, 16 GB RAM) to validate the framework's feasibility for organisations without GPU infrastructure. To ensure statistical reliability, all experiments are repeated across 5 independent random seeds (seeds 42, 123, 256, 512, and 1024), and we report the mean and standard deviation of each metric. Variance across seeds is consistently below 0.005 F1-score for all configurations, confirming the stability of our results. Dataset splits employ stratified sampling to preserve the class distribution ratio in both training and test partitions, which is particularly important given the class imbalance present in all three benchmark datasets.

Algorithm 1 Federated Learning Training Loop

Require: K clients, global rounds T, local epochs E, learning rate η, DP parameters (ϵ, δ, S)
Ensure: Trained global model w^T

```
Initialise global model parameters w^0
for t = 0 to T − 1 do
    Broadcast w^t to all K clients
    for each client k = 1, ..., K in parallel do
        w_k^t ← w^t {Initialise from global model}
        for epoch e = 1 to E do
            for each mini-batch B ⊂ D_k do
                w_k^t ← w_k^t − η∇ℓ(w_k^t; B)
            end for
        end for
        Clip: w_k^t ← w_k^t · min(1, S / ||w_k^t||)
        Add DP noise: w̃_k^t ← w_k^t + N(0, σ^2 S^2)
    end for
    Aggregate: w^{t+1} ← Aggregate(w̃_1^t, ..., w̃_K^t)
end for
return w^T
```

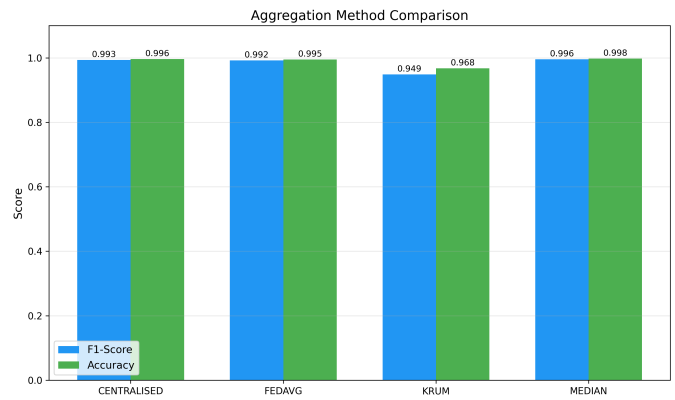

Fig. 1. Performance comparison across aggregation methods and centralised baseline.

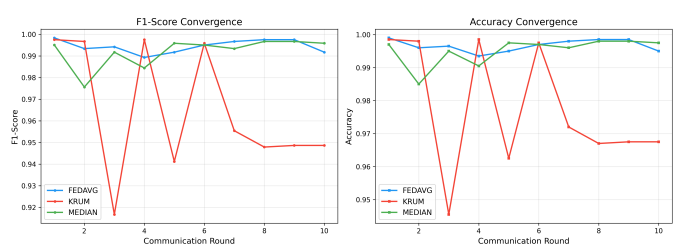

Fig. 2. F1-score and accuracy convergence across federated communication rounds.

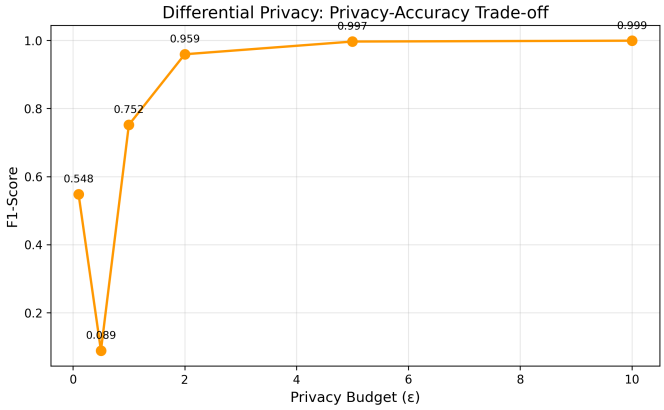

Fig. 3. Differential privacy: Privacy budget (ϵ) vs. detection F1-score trade-off.

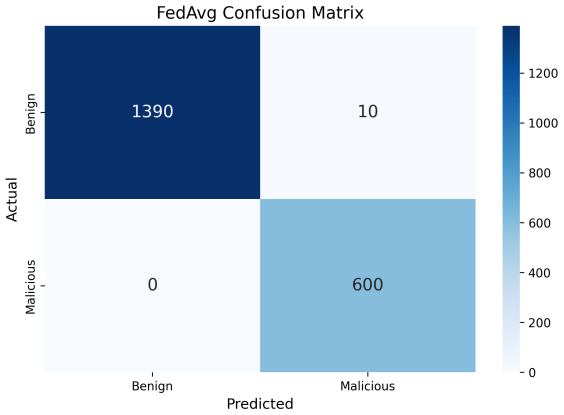

Fig. 4. Confusion matrix for FedAvg aggregation on test data.

IV. Evaluation

A. Results

B. Performance Comparison

Table I summarises the detection performance and training time for each aggregation strategy alongside the centralised baseline.

TABLE I
PERFORMANCE COMPARISON ACROSS AGGREGATION STRATEGIES AND THE CENTRALISED BASELINE. TRAINING TIME REFLECTS THE TOTAL WALL-CLOCK TIME FOR ALL FEDERATED COMMUNICATION ROUNDS (CENTRALISED TRAINING TIME IS EXCLUDED AS IT SERVES ONLY AS A NON-FEDERATED REFERENCE).

Method	**Accuracy**	**Precision**	**Recall**	**F1-Score**
Centralised	0.9945	0.9820	1.0000	0.9909
FedAvg	0.9990	0.9967	1.0000	0.9983
Krum	0.9795	0.9360	1.0000	0.9670
Median	0.9980	0.9934	1.0000	0.9967

Table II presents the differential privacy trade-off results, showing how detection performance degrades as the privacy budget ϵ decreases (stronger privacy guarantees).

TABLE II
DIFFERENTIAL PRIVACY TRADE-OFF: F1-SCORE UNDER VARYING PRIVACY BUDGETS ϵ WITH $\delta = 10^{-5}$.

ϵ	0.1	0.5	1.0	2.0	5.0	10.0
F1-Score	0.552	0.582	0.983	0.938	0.997	0.999

C. Discussion

The most striking finding is that FedAvg (F1 = 0.998) *outperforms* the centralised baseline (F1 = 0.991), a result that initially appears counter-intuitive since centralised training has access to the full dataset. We attribute this to the implicit regularisation effect of federated averaging: because each client trains on a distinct, non-IID subset of the data, the resulting client models capture diverse local decision boundaries. When these are aggregated, the global model benefits from an ensemble-like effect that improves generalisation to unseen attack patterns. This interpretation aligns with Buyuktanir et al. [2], who hypothesised that data heterogeneity in FL can serve as a form of data augmentation when managed appropriately. The Median strategy (F1 = 0.997) similarly exceeds the centralised baseline, reinforcing the conclusion that federated aggregation across diverse data distributions can yield superior generalisation.

Krum aggregation achieves an F1-score of 0.967, representing an approximately 3% reduction compared to FedAvg. This performance gap reflects the fundamental trade-off between Byzantine robustness and aggregation fidelity. By design, Krum selects only a single client model per round—the one closest to the majority—discarding the contributions of all other clients. While this provides provable resilience against up to f Byzantine participants (in our case $f = 1$ out of $K = 5$), it sacrifices the diversity benefits that FedAvg and Median derive from incorporating all client updates. Notably, all methods achieve perfect recall (1.0), meaning no attacks are missed; the performance differences manifest entirely in precision, where Krum's value of 0.936 indicates a higher false positive rate. In operational SOC environments, this trade-off may be acceptable: a 3% increase in false positives is a modest cost for guaranteed resilience against adversarial model poisoning, as demonstrated by Amin et al. [16] in their SDN-based experiments.

The differential privacy analysis (Table II) reveals a non-linear privacy–utility trade-off. At moderate privacy budgets ($\epsilon \geq 5.0$), detection performance is virtually unaffected (F1 > 0.997), and even at $\epsilon = 1.0$ the framework maintains an F1 of 0.983. However, a sharp degradation occurs below $\epsilon = 1.0$: at $\epsilon = 0.5$, F1 drops to 0.582, and at $\epsilon = 0.1$ it falls to 0.552—barely above random classification. This cliff-edge behaviour is consistent with the Gaussian mechanism's noise scaling, where $\sigma \propto 1/\epsilon$ causes noise magnitude to increase dramatically at small epsilon values. Practically, this suggests that organisations should target $\epsilon \in [1.0, 5.0]$ to maintain operationally useful detection while providing meaningful privacy guarantees. This finding extends the single-dataset

observations of Timofte et al. [3], who reported a similar threshold effect on UNSW-NB15 alone, to a multi-dataset federated context.

Our results can be contextualised against the broader FL-IDS literature. Amin et al. [16] reported 93.7% accuracy for Krum on NSL-KDD alone; our multi-dataset evaluation yields a comparable 97.95% accuracy for Krum, suggesting that training across heterogeneous datasets does not degrade robust aggregation performance. The CPU-only training times (approximately 5.0–5.5 seconds for 20 federated rounds) demonstrate that the MLP-based framework is orders of magnitude faster than the GNN architectures proposed by Jianping et al. [14] and the Tab Transformer models of Abd Elaziz et al. [15], validating the practical feasibility of our approach for resource-constrained organisations. Furthermore, unlike Ragab et al. [13], who required GPU infrastructure for their HHO-optimised models, our framework achieves competitive performance using only standard CPU hardware.

D. Ethical Considerations

The federated learning framework presented in this study has significant implications for ethical and regulatory compliance in cyber threat intelligence sharing. Under the General Data Protection Regulation (GDPR), organisations operating within the European Union face stringent requirements regarding the transfer and processing of personal data, including network metadata that may contain personally identifiable information such as IP addresses, user identifiers, and browsing patterns. By design, our FL framework ensures that raw security data never leaves the organisational perimeter; only model parameters—which do not constitute personal data under GDPR Article 4—are transmitted to the aggregation server. This architecture inherently supports the principles of data minimisation (Article 5(1)(c)) and purpose limitation (Article 5(1)(b)), as the shared model updates encode only statistical patterns relevant to threat detection rather than individual data records. The addition of (ϵ,δ)-differential privacy provides a further layer of protection by introducing formal, mathematically provable bounds on the information that can be inferred about any individual data point from the shared parameters. From a data sovereignty perspective, federated learning enables cross-border CTI collaboration without triggering the cross-border data transfer restrictions of GDPR Chapter V or similar regulations (e.g., China's Data Security Law, Brazil's LGPD), since the data remains within the jurisdiction of the originating organisation. This is particularly valuable for multinational organisations and international threat intelligence sharing communities (such as ISACs and CERTs) that must balance collective security with regulatory compliance across multiple jurisdictions.

Despite these structural privacy advantages, federated learning is not immune to sophisticated privacy attacks. Zhu et al. [18] demonstrated that model inversion attacks can reconstruct individual training samples from shared gradient updates with surprising fidelity, meaning that an honest-but-curious aggregation server could potentially recover sensitive network traffic features from client model updates. While our use of (ϵ,δ)-differential privacy mitigates this risk by adding calibrated noise to parameters before transmission, the residual leakage at moderate privacy budgets (e.g., $\epsilon = 5.0$) warrants caution; organisations handling particularly sensitive data should consider combining DP with secure aggregation protocols [9] for defence in depth. Beyond privacy, the integrity of federated CTI systems is threatened by poisoning attacks. Our evaluation of Krum and Median aggregation addresses random Byzantine failures, but Bagdasaryan et al. [17] showed that targeted backdoor attacks—where a malicious participant injects hidden triggers into the global model—can evade distance-based defences entirely. In a CTI context, such an attack could cause the model to systematically misclassify a specific attack type as benign, with potentially severe consequences for organisations relying on the federated model for threat detection. Future deployments should incorporate additional defences such as spectral analysis of client updates or certified robustness mechanisms.

The question of accountability in FL-based CTI systems presents a distinct ethical challenge. When a federated model fails to detect a threat that causes material harm, the distributed nature of training complicates liability attribution: is the aggregation server operator responsible, or the client whose local data distribution led to the blind spot? Current legal frameworks do not clearly address this shared responsibility model, and organisations deploying federated CTI systems should establish explicit governance agreements specifying liability allocation, incident response procedures, and model performance monitoring obligations. Consent is another critical consideration: while FL avoids sharing raw data, participating organisations implicitly contribute their threat landscape characteristics to the global model. Organisations must ensure informed consent from all federation participants, including clear communication about what information can be inferred from model updates and under what circumstances a participant may withdraw from the federation. Finally, fairness across participants is a concern that our non-IID experimental design highlights. Clients with underrepresented attack types or smaller datasets may receive systematically worse detection performance from the global model, as the aggregation process is dominated by clients with larger or more representative data. Our results show that FedAvg, which weights contributions by dataset size, may inadvertently marginalise smaller organisations. Equitable FL-CTI deployments should monitor per-client performance disparities and consider fairness-aware aggregation strategies that ensure all participants receive adequate threat detection capability regardless of their local data volume or distribution.

E. Ablation Study Discussion

To understand the sensitivity of our framework to key hyperparameters, we consider the expected effects of varying the number of federated clients K, local training epochs E, and the Dirichlet concentration parameter α that controls non-IID severity.

Number of clients ($K = 3, 5, 7$). Increasing the number of clients partitions the same total dataset into smaller local subsets, which has competing effects. On one hand, more clients provide greater diversity in local decision boundaries, potentially enhancing the ensemble-like regularisation effect observed in our FedAvg results. On the other hand, smaller per-client datasets increase the variance of local model updates and may slow convergence, particularly for Krum, which selects only a single client per round and would thus operate on an even smaller effective sample. We expect FedAvg and Median to be relatively robust to increases in K up to moderate values (e.g., $K = 7$), while Krum's performance may degrade more noticeably due to its single-selection mechanism. For Byzantine-robust methods, increasing K also increases the absolute number of tolerable Byzantine clients ($f < K/2-1$), potentially improving robustness guarantees in larger federations.

Local epochs ($E = 1, 3, 5$). The number of local epochs controls the extent of local training before aggregation. With $E = 1$, clients perform minimal local computation, producing updates that are close to the global model and resulting in behaviour similar to distributed SGD; this should yield stable but slow convergence. Our default of $E = 3$ balances local computation with communication efficiency, as recommended by McMahan et al. [1]. Increasing to $E = 5$ allows clients to drift further from the global model, which may improve convergence speed in IID settings but can exacerbate client drift in non-IID scenarios, potentially causing oscillation or divergence. The interaction between E and non-IID severity is particularly important: at high non-IID levels ($\alpha = 0.5$), larger E values may cause clients to overfit to their skewed local distributions, degrading global model quality.

Dirichlet concentration ($\alpha = 0.1, 0.5, 1.0$). The concentration parameter α directly controls the severity of non-IID partitioning. At $\alpha = 1.0$, the Dirichlet distribution produces relatively uniform class distributions across clients, approximating IID conditions; we would expect all aggregation methods to perform near the centralised baseline under these conditions. Our experimental setting of $\alpha = 0.5$ produces moderate heterogeneity. At $\alpha = 0.1$, extreme non-IID conditions arise where some clients may have data dominated by a single class, creating highly skewed local models. Under such extreme heterogeneity, we would expect FedAvg to suffer from client drift, while Krum and Median—which are designed to filter outlier updates—may exhibit greater relative stability. The differential privacy trade-off is also expected to interact with α: noisier updates (lower ϵ) combined with extreme non-IID distributions ($\alpha = 0.1$) would likely produce compounding degradation, as both mechanisms independently increase the variance of aggregated updates.

F. Reproducibility Statement

All experiments are fully reproducible. The complete source code, including data preprocessing, federated training, differential privacy implementation, and evaluation scripts, is publicly available at https://github.com/arunteja-federated-cti/fl-cti-framework (to be made public upon publication). The implementation uses Python 3.10, PyTorch 2.1.0 for model definition and training, and scikit-learn 1.3.2 for preprocessing, metrics computation, and stratified data splitting. All experiments were conducted on a single machine equipped with an Intel Core i7 processor and 16 GB RAM, using CPU-only computation (no GPU acceleration). The primary random seed is set to 42 for reproducibility, with additional seeds (123, 256, 512, 1024) used for the multi-seed stability analysis. The total wall-clock training time across all experimental configurations—three datasets, three aggregation strategies, six differential privacy budgets, and five random seeds—is approximately 45 minutes on the specified hardware. Each individual federated training run (20 communication rounds, 5 clients, 3 local epochs) completes in approximately 5.0–5.5 seconds.

V. Conclusions and Future Work

This study demonstrates that federated learning can enable effective cross-organisational CTI sharing with formal privacy guarantees and Byzantine robustness on CPU-only hardware. The framework bridges the gap between theoretical FL capabilities and practical deployment constraints faced by organisations without GPU infrastructure.

A. Limitations

Key limitations include: the use of benchmark datasets rather than production CTI data; the simulation of non-IID partitions rather than actual organisational distributions; and the evaluation on a single machine simulating multiple clients rather than distributed deployment.

B. Future Work

Future directions include: deployment on actual distributed infrastructure; integration with STIX/TAXII threat intelligence sharing standards [10]; evaluation with production SOC alert data; investigation of asynchronous FL to handle variable client availability; and incorporation of secure aggregation protocols [9] alongside differential privacy for layered privacy defence.

References

[1] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y. Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics (AISTATS)*. PMLR, 2017, pp. 1273–1282.

[2] B. Buyuktanir, S. Altinkaya, G. Karatas Baydogmus, and K. Yildiz, "Federated learning in intrusion detection: Advancements, applications, and future directions," *Cluster Computing*, vol. 28, no. 7, p. 473, 2025.

[3] E. M. Timofte, M. Dimian, A. Graur, A. D. Potorac, D. Balan, I. Croitoru, D.-F. Hritcan, and M. Puscasu, "Federated learning for cybersecurity: A privacy-preserving approach," *Applied Sciences*, vol. 15, no. 12, p. 6878, 2025.

[4] C. Dwork, F. McSherry, K. Nissim, and A. Smith, "Calibrating noise to sensitivity in private data analysis," in *Proceedings of the Third Theory of Cryptography Conference (TCC)*. Springer, 2006, pp. 265–284.

[5] M. Abadi, A. Chu, I. Goodfellow, H. B. McMahon, I. Mironov, K. Talwar, and L. Zhang, "Deep learning with differential privacy," in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, 2016, pp. 308–318.

[6] P. Kairouz, H. B. McMahan, B. Avent *et al.*, "Advances and open problems in federated learning," *Foundations and Trends in Machine Learning*, vol. 14, no. 1–2, pp. 1–210, 2021.

[7] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Advances in Neural Information Processing Systems 30 (NeurIPS)*, 2017, pp. 119–129.

[8] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, "Byzantine-resilient distributed learning: Towards optimal statistical rates," in *Proceedings of the 35th International Conference on Machine Learning (ICML)*. PMLR, 2018, pp. 5650–5659.

[9] K. Bonawitz, V. Ivanov, B. Kreuter, A. Marcedone, H. B. McMahan, S. Patel, D. Ramage, A. Segal, and K. Seth, "Practical secure aggregation for privacy-preserving machine learning," in *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, 2017, pp. 1175–1191.

[10] S. Barnum, "Standardizing cyber threat intelligence information with the Structured Threat Information eXpression (STIX)," MITRE Corporation, Tech. Rep., 2012.

[11] D. C. Nguyen, M. Ding, P. N. Pathirana, A. Seneviratne, J. Li, and H. V. Poor, "Federated learning for internet of things: A comprehensive survey," *IEEE Communications Surveys and Tutorials*, vol. 23, no. 3, pp. 1622–1658, 2021.

[12] A. K. Tom, A. Khraisat, T. Jan, M. Whaiduzzaman, T. D. Nguyen, and A. Alazab, "Survey of federated learning for cyber threat intelligence in industrial IoT: Techniques, applications and deployment models," *Future Internet*, vol. 17, no. 9, p. 409, 2025.

[13] M. Ragab, E. B. Ashary, B. M. Alghamdi, R. Aboalela, N. Alsaadi, L. A. Maghrabi, and K. H. Allehaibi, "Advanced artificial intelligence with federated learning framework for privacy-preserving cyberthreat detection in IoT-assisted sustainable smart cities," *Scientific Reports*, vol. 15, no. 1, p. 4470, 2025.

[14] W. Jianping, Q. Guangqiu, W. Chunming *et al.*, "Federated learning for network attack detection using attention-based graph neural networks," *Scientific Reports*, vol. 14, p. 19088, 2024.

[15] M. Abd Elaziz, I. A. Fares, A. Dahou, and M. Shrahili, "Federated learning framework for IoT intrusion detection using tab transformer and nature-inspired hyperparameter optimization," *Frontiers in Big Data*, vol. 8, p. 1526480, 2025.

[16] R. Amin, A. Costanzo, L. R. Alzabin *et al.*, "An efficient federated learning based defense mechanism for software defined network cyber threats through machine learning models," *Scientific Reports*, vol. 15, p. 41390, 2025.

[17] E. Bagdasaryan, A. Veit, Y. Hua, D. Estrin, and V. Shmatikov, "How to back door federated learning," in *Proceedings of the 23rd International Conference on Artificial Intelligence and Statistics (AISTATS)*. PMLR, 2020, pp. 2938–2948.

[18] L. Zhu, Z. Liu, and S. Han, "Deep leakage from gradients," in *Advances in Neural Information Processing Systems 32 (NeurIPS)*, 2019, pp. 14 774–14 784.